



MODUL 15 · DEPLOYMENT & PRODUCTION

Security Checklist *Production*

Update dependencies, validasi input, rate limiting — tiga pilar security sebelum launch.



Update Dependencies — Patch CVE Secara Rutin

CVE-2025-29927 (Next.js) adalah reminder: dependencies lama = vulnerabilities aktif.

● ● ● Cara update dependencies yang aman

```
# — Cek dependencies yang outdated —————
bun outdated
# Tampilkan semua package + versi saat ini vs terbaru

# — Cek vulnerability yang diketahui —————
bun audit
# Tampilkan CVE yang affect dependencies kita

# — Update satu package (safe) —————
bun update next
bun update react react-dom
bun update @prisma/client prisma

# — Update semua ke versi minor/patch (aman) —————
bun update
# Minor/patch updates: aman dilakukan

# — JANGAN update major tanpa testing —————
# Major version = kemungkinan breaking changes
# Baca CHANGELOG sebelum update major

# — Setelah update: selalu test —————
bun run build          # pastikan build sukses
bun run dev            # test manual semua fitur utama
# Jalankan test jika ada

# — Otomasi dengan Dependabot —————
# .github/dependabot.yml — Dependabot buat PR otomatis untuk updates
# package-ecosystem: "npm"
# schedule: interval: "weekly"
```

Validasi Input & Rate Limiting

Semua input dari user harus divalidasi. Rate limiting mencegah abuse dan DoS.

```
# bun add @upstash/ratelimit @upstash/redis

import { Ratelimit } from "@upstash/ratelimit"
import { Redis } from "@upstash/redis"

// Inisialisasi rate limiter
const ratelimit = new Ratelimit({
  redis: Redis.fromEnv(),
  limiter: Ratelimit.slidingWindow(10, "10 s"),
  // ↑ max 10 request per 10 detik per identifier
})

// Di Server Action atau Route Handler:
export async function createPost(formData: FormData) {
  "use server"
  const session = await auth.api.getSession(...)
  if (!session) return { error: "Unauthorized" }

  // Rate limit berdasarkan user ID
  const { success, remaining } = await ratelimit.limit(
    `create-post:${session.user.id}`
  )
  if (!success) {
    return { error: `Rate limit exceeded. Try again later.` }
  }

  // Lanjutkan operasi normal...
}
```

```
// — Validasi SEMUA input dengan Zod —————
// Sudah diajarkan di Modul 11 dan 12
// Reminder: JANGAN skip ini di production!

// — Sanitasi string yang akan di-display —————
// Next.js dengan JSX otomatis escape HTML
// AMAN: <p>{userContent}</p>
// BAHAYA: <p dangerouslySetInnerHTML={{ __html:userContent }} />

// — File upload validation —————
// Sudah diajarkan di Modul 14
// MIME type + size + generate nama sendiri

// — SQL injection: Prisma AMAN by default —————
// Prisma menggunakan parameterized queries
// AMAN: db.post.findMany({ where: { title: userInput } })
// BAHAYA: db.$queryRaw`SELECT * WHERE title = ${userInput}`
// ↑ Hati-hati dengan $queryRaw!

// — CSRF: Server Actions otomatis protected —————
// CSRF token tidak perlu manual
// Next.js Server Actions sudah include CSRF protection

// — Auth headers: jangan percaya x-user-id —————
// SELALU baca session dari cookie
// JANGAN percaya header yang dikirim client!
```

Production Security Checklist

Jalankan checklist ini sebelum launch dan setiap major release.

Authentication

- ✓ Session check di SETIAP protected page dan Server Action
- ✓ RBAC check untuk admin-only features
- ✓ BETTER_AUTH_URL = production URL (bukan localhost)
- ✓ OAuth redirect URLs diupdate ke production domain

Data Security

- ✓ Semua input divalidasi dengan Zod
- ✓ Ownership check: WHERE userId = session.user.id
- ✓ Tidak ada SQL injection via \$queryRaw tanpa sanitasi
- ✓ File upload: MIME + size validation + random filename

Dependencies

- ✓ Next.js 16+ (fix CVE-2025-29927)
- ✓ bun audit: tidak ada critical vulnerability
- ✓ Dependabot atau update rutin terjadwal
- ✓ CHANGELOG dibaca sebelum major update

Infrastructure

- ✓ HTTPS enforced (Vercel otomatis)
- ✓ Env vars di Vercel dashboard, bukan di file yang di-commit
- ✓ Rate limiting untuk endpoints publik dan mutasi
- ✓ Error monitoring (Sentry) untuk tangkap error production

Evaluasi Pemahaman

Jawab sebelum lanjut.

Q1 — Perintah apa yang digunakan untuk mengecek CVE yang mempengaruhi project?

- A) bun check-security B) bun audit — menampilkan known vulnerabilities di dependencies C) bun outdated

Q2 — Rate limiting identifier mana yang lebih baik untuk API publik?

- A) IP address saja B) User ID (jika login) atau IP (jika guest) — IP bisa shared, userId lebih precise C) Session token

Q3 — Apakah Server Actions di Next.js butuh CSRF token manual?

- A) Ya — harus tambahkan CSRF token ke setiap form B) Tidak — Next.js Server Actions sudah include CSRF protection otomatis C) Tergantung apakah pakai Better Auth

Tugas Mandiri

Jalankan security audit penuh sebelum launch.

01 Dependency Audit

Jalankan bun audit dan bun outdated. Fix semua critical/high vulnerabilities. Update Next.js ke versi terbaru. Dokumentasikan perubahan.

02 Rate Limiting

Setup Upstash Redis (upstash.com → free tier). bun add @upstash/ratelimit @upstash/redis. Tambahkan rate limit ke: login, createPost, uploadFile.

03 Security Scan

Gunakan vercel.com/security atau OWASP ZAP untuk basic scan. Identifikasi: missing headers, exposed env vars, open redirects.

04 Final Checklist

Jalankan semua item di production security checklist. Tandai yang sudah selesai. Prioritaskan yang belum selesai sebelum launch.

 Sebelum launch: bun audit (zero criticals), auth check di semua protected routes, rate limiting aktif.

Yang Sudah Kita Pelajari

- ✓ bun audit: cek CVE. bun outdated: cek versi lama. Update rutin mencegah vulnerability.
- ✓ Rate limiting dengan Upstash: max request per waktu per identifier. Cegah abuse.
- ✓ Validasi input (Zod) + MIME check + ownership check + CSRF auto (Server Actions).
- ✓ Security checklist: Authentication, Data Security, Dependencies, Infrastructure.
- ✓ Launch checklist: zero critical CVE, auth di semua routes, rate limiting, error monitoring.

→ Selanjutnya: **Modul 16 — Project Akhir: Project Management Dashboard**

